

Evaluasi Keamanan Aplikasi Web Menggunakan Helium Security Dengan Metode Black-Box Testing: Studi Kasus Universitas Muhammadiyah Tegal

Audrey Tarita Aurellia (2402008)

Program Studi D3 Teknik Informatika, Politeknik Purbaya, Kabupaten Tegal

ABSTRAK

Penelitian ini berfokus pada evaluasi keamanan aplikasi web Universitas Muhammadiyah Tegal. Pengujian ini merupakan bagian dari tahapan Vulnerability Assessment guna memetakan postur keamanan web server secara otomatis menggunakan alat pemindai keamanan Helium Security. Skenario pengujian dilakukan dengan pendekatan Black-box testing pada domain utama (<https://umtegal.ac.id>), di mana penguji bertindak layaknya pengguna eksternal tanpa memiliki akses kredensial, arsitektur jaringan, maupun kode sumber. Hasil pemindaian menunjukkan bahwa sistem memiliki tingkat keamanan dasar yang cukup baik, ditandai dengan tidak ditemukannya kerentanan dengan tingkat keparahan Kritis (Critical) maupun Tinggi (High). Walau demikian, sistem mendeteksi adanya 6 (enam) celah keamanan yang tersebar pada tingkat Menengah (Medium), Rendah (Low), dan Informasional. Mayoritas kerentanan ini disebabkan oleh miskonfigurasi keamanan pada level web server, khususnya ketiadaan implementasi HTTP Security Headers dan adanya kebocoran informasi (Information Disclosure) melalui header respons. Rekomendasi mitigasi yang diusulkan bagi administrator sistem meliputi penerapan Security Headers (seperti HSTS dan nosniff), pencegahan kebocoran informasi dari header X-Powered-By, serta pembatasan akses firewall pada port administratif yang terbuka ke publik.

Kata Kunci: Vulnerability Assessment, Black-Box Testing, Helium Security, HTTP Security Headers, Keamanan Web.

Evaluasi Keamanan Aplikasi Web Menggunakan Helium Security Dengan Metode Black-Box Testing: Studi Kasus Universitas Muhammadiyah Tegal

ABSTRACT

This research focuses on the web application security evaluation of Universitas Muhammadiyah Tegal. This test is part of the Vulnerability Assessment phase to automatically map the web server's security posture using the Helium Security scanner tool. The testing scenario was conducted using a Black-box testing approach on the main domain (<https://umtegal.ac.id>), where the tester acted as an external user without any credential access, knowledge of network architecture, or source code. The scanning results indicate that the system has an adequate baseline security level, characterized by the absence of vulnerabilities with Critical or High severity. Nevertheless, the system detected 6 (six) security flaws distributed across the Medium, Low, and Informational levels. The majority of these vulnerabilities were caused by security misconfigurations at the web server level, specifically the lack of HTTP Security Headers implementation and Information Disclosure via response headers. The mitigation recommendations proposed for system administrators include the implementation of Security Headers (such as HSTS and nosniff), prevention of information leakage from the X-Powered-By header, and firewall access restrictions on administrative ports exposed to the public.

Keywords: Vulnerability Assessment, Black-Box Testing, Helium Security, HTTP Security Headers, Web Security.

I. PENDAHULUAN

Perkembangan teknologi informasi dan komunikasi telah mendorong institusi pendidikan tinggi untuk mengadopsi sistem informasi akademik berbasis web. Situs web universitas kini berfungsi sebagai gerbang utama untuk aktivitas akademik, penerimaan

mahasiswa baru, dan pengelolaan data internal. Namun, seiring meningkatnya ketergantungan pada infrastruktur digital, ancaman terhadap keamanan siber juga semakin tinggi. Institusi pendidikan sering kali menjadi target serangan siber karena menyimpan data yang bernilai tinggi, seperti data pribadi mahasiswa, rekam jejak akademik, hingga kekayaan intelektual riset. Kebocoran data tidak hanya merugikan secara finansial, tetapi juga dapat merusak reputasi institusi, sehingga pengujian keamanan sistem secara berkala merupakan langkah preventif yang esensial (Riadi and W, 2020). Mengingat pentingnya data yang tersimpan, pengujian kerentanan web sangat diperlukan agar terhindar dari akses pihak yang tidak bertanggung jawab (Elanda and Buana, 2021).

Dalam konteks *Ethical Hacking*, *Vulnerability Assessment* (penilaian kerentanan) adalah tahapan krusial untuk mengidentifikasi, mengklasifikasi, dan memitigasi celah keamanan sebelum pihak yang tidak bertanggung jawab mengeksploitasinya. Penelitian ini berfokus pada evaluasi keamanan aplikasi web Universitas Muhammadiyah Tegal. Pengujian dibatasi secara spesifik pada domain utama institusi (<https://umtegal.ac.id>) menggunakan fitur *Basic Scan* dari tools Helium Security, tanpa melakukan eksploitasi aktif (*active exploitation*) yang dapat merusak layanan. Tujuan utama penelitian ini adalah mengetahui tingkat risiko sistem, mengklasifikasikan kerentanan berdasarkan *Severity Level*, dan menyusun rekomendasi teknis perbaikan (*patching/hardening*) bagi administrator sistem.

2. TINJAUAN PUSTAKA

A. Penetration Testing dan Vulnerability Assessment

Penetration Testing (uji penetrasi) adalah metode evaluasi keamanan sistem dengan cara menyimulasikan serangan. *Vulnerability Assessment* bertujuan untuk memindai, mengidentifikasi, dan memetakan kelemahan secara otomatis maupun manual. Banyak instansi yang membangun *web server* atau sistem informasi tanpa memperhatikan apakah sistem tersebut sudah sesuai standar keamanan atau rentan terhadap gangguan, sehingga evaluasi ini sangat dibutuhkan (Guntoro, Costaner, L., 2020).

B. Black-Box Testing

Metode pengujian di mana auditor keamanan tidak memiliki pengetahuan internal mengenai *source code*, arsitektur jaringan, maupun hak akses (*credential*) dari sistem target. Penguji bertindak layaknya pengguna biasa atau peretas eksternal bermodalkan URL publik atau alamat IP.

C. Konfigurasi Keamanan Web Server (HTTP Security Headers)

Header ini merupakan parameter yang dikirimkan oleh web server kepada *browser* klien untuk memitigasi serangan injeksi dan pencurian data. Dua header krusial adalah X-Content-Type-Options (mencegah *MIME-sniffing*) dan Strict-Transport-Security (HSTS) yang memaksa browser menggunakan koneksi HTTPS terenkripsi. Ketidadaan enkripsi HTTPS memungkinkan peretas melakukan penyadapan (*sniffing*) untuk mencuri informasi penting seperti username dan password melalui serangan Man-in-the-Middle (Luthfansa and Rosiani, 2021).

D. Information Disclosure

Kebocoran informasi terjadi ketika server mengekspos data internal yang seharusnya tidak diketahui publik, seperti tereksposnya header respons HTTP X-Powered-By yang membocorkan bahasa pemrograman atau *framework* yang digunakan.

E. Helium Security

Tools ini merupakan *Security Testing* berbasis *cloud* yang mampu melakukan inspeksi port (*port scanning*), identifikasi teknologi peladen (*tech stack footprinting*), dan pemindaian kerentanan pada tingkat aplikasi web (*website scanner*) secara otomatis dan terukur.

3. METODOLOGI PENELITIAN

Penelitian ini menggunakan pendekatan evaluasi keamanan siber yang bersifat observasional dan analitis. Objek utama yang dievaluasi dalam penelitian ini adalah sistem informasi dan aplikasi berbasis web milik Universitas Muhammadiyah Tegal, yang diakses melalui domain utama publik (<https://umtegal.ac.id>). Pengujian ini dilakukan dengan mengedepankan prinsip *Ethical Hacking*, di mana proses pemindaian dilakukan secara pasif dan semi-aktif tanpa melakukan eksploitasi yang bersifat merusak (*non-destructive testing*) guna memastikan layanan akademik tetap berjalan normal tanpa gangguan selama penelitian berlangsung.

Pengujian dilakukan secara otomatis menggunakan perangkat lunak layanan keamanan berbasis *cloud* yaitu *Helium Security*. Fitur yang digunakan adalah *Website Scanner* dengan mengaktifkan parameter *Basic Scan*. Skenario pengujian secara murni mengadopsi metode *Black-Box Testing*. Dalam metode ini, peneliti memposisikan diri sebagai penyerang atau entitas eksternal (pihak luar) yang sama sekali tidak memiliki akses kredensial (seperti *username* dan *password*), tidak mengetahui topologi jaringan internal target, serta tidak

memiliki akses ke dalam kode sumber (*source code*) maupun basis data. Pendekatan ini bertujuan untuk mengukur secara realistis sejauh mana permukaan serangan (*attack surface*) yang terekspos secara publik dan dapat dilihat oleh siapa saja di internet.

Secara sistematis, alur penelitian ini dibagi ke dalam tiga tahapan utama yang merujuk pada standar siklus pengujian keamanan aplikasi web, yaitu:

A. Pengumpulan Informasi (*Reconnaissance / Information Gathering*)

Tahap ini merupakan fase awal yang sangat krusial untuk mengumpulkan data intelijen sebanyak mungkin mengenai target sebelum pemindaian utama dilakukan. Langkah-langkah analitis yang dilakukan pada tahap ini meliputi:

- Resolusi DNS dan Identifikasi IP: Mengonversi nama domain (umtegal.ac.id) menjadi alamat IP publik untuk menentukan lokasi *host* dari server yang digunakan oleh institusi.
- Pemindaian Port (*Port Scanning*): Melacak dan mengidentifikasi *port* jaringan mana saja yang berstatus terbuka (*open*), tertutup (*closed*), atau terfilter (*filtered*) oleh *firewall*. Selain itu, proses ini juga bertujuan untuk mengetahui layanan (*services*) apa saja yang berjalan di balik *port* tersebut (misalnya layanan HTTP/HTTPS, layanan transfer berkas/FTP, hingga layanan manajemen basis data/MySQL).
- Pemetaan Teknologi Backend (*Tech-Stack Fingerprinting*): Melakukan deteksi pasif terhadap tumpukan teknologi yang membangun situs web target. Hal ini mencakup identifikasi jenis *web server* (misalnya LiteSpeed), Sistem Manajemen Konten (CMS) yang terinstal (seperti WordPress beserta *plugin* bawaannya), versi bahasa pemrograman (*backend language*) seperti PHP, hingga tipe koneksi keamanan yang diterapkan.

B. Pemindaian Kerentanan (*Vulnerability Scanning*)

Setelah profil dan arsitektur target berhasil dipetakan, tahap selanjutnya adalah melakukan inspeksi kerentanan secara terotomatisasi menggunakan mesin pemindai Helium Security. Pada fase ini, sistem *scanner* akan menjalankan serangkaian proses berikut:

- Inspeksi Interaksi Klien-Server: Mengirimkan serangkaian *request* (permintaan) HTTP/HTTPS secara terstruktur ke *server* target dan menganalisis respons yang diberikan untuk mendeteksi anomali pada arsitektur web.

- Pencocokan Basis Data Kerentanan (CVE Matching): Membandingkan versi perangkat lunak, sistem operasi, maupun *plugin* yang ditemukan pada fase *reconnaissance* dengan basis data kelemahan global yang telah terpublikasi, seperti *Common Vulnerabilities and Exposures* (CVE).
- Analisis Konfigurasi Keamanan Web: Mengevaluasi konfigurasi lapisan aplikasi, khususnya dalam implementasi parameter *HTTP Security Headers* (seperti evaluasi kebijakan *Strict-Transport-Security* atau HSTS dan *X-Content-Type-Options*). Pada tahap ini, *scanner* juga mendeteksi adanya potensi kebocoran informasi (*Information Disclosure*) dari respons *header* maupun miskonfigurasi pada direktif *cache*.

C. Analisis Hasil dan Pelaporan (*Analysis and Reporting*)

Tahap akhir dari metodologi ini adalah melakukan validasi, kategorisasi, dan penyusunan strategi mitigasi atas seluruh temuan (*logs*) yang dihasilkan oleh Helium Security. Langkah-langkah penyelesaiannya meliputi:

- Kategorisasi Risiko (*Risk Categorization*): Mengklasifikasikan setiap temuan kerentanan berdasarkan tingkat keparahannya (*Severity Level*) menggunakan metrik yang relevan (seperti acuan CVSS). Temuan dikelompokkan ke dalam lima tingkatan, yaitu *Critical* (Kritis/sangat rentan dieksploitasi), *High* (Tinggi), *Medium* (Menengah), *Low* (Rendah), dan *Informational* (Hanya sekadar peringatan anomali konfigurasi standar).
- Perumusan Rekomendasi Mitigasi (*Hardening Strategy*): Berdasarkan hasil klasifikasi, peneliti menganalisis dampak dari masing-masing celah dan menyusun rekomendasi perbaikan teknis (*patching* atau *hardening*) yang spesifik. Rekomendasi ini dirumuskan sebagai pedoman bagi pihak administrator sistem institusi untuk menambal celah keamanan, mengonfigurasi ulang perlindungan server, dan meminimalkan risiko serangan siber di masa mendatang.

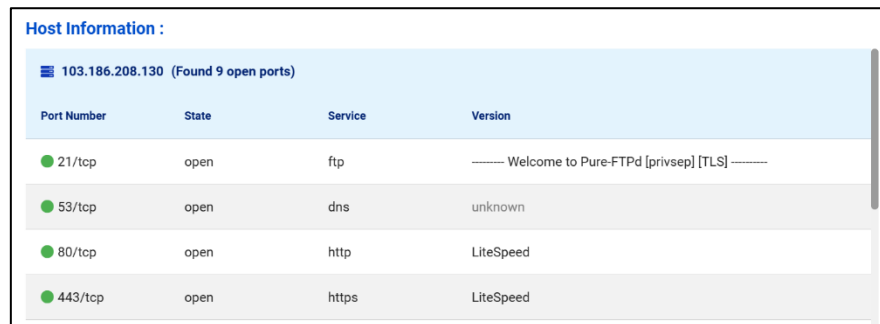
4. HASIL DAN PEMBAHASAN

A. Hasil Pengumpulan Informasi (*Information Gathering*)

Pemindaian pada target beralamat IP 103.186.208.130 menemukan 9 port yang berstatus terbuka (*open*), sebagaimana diuraikan pada Tabel 1. Banyaknya port yang terbuka, terutama port basis data (3306), memperlebar permukaan serangan (*attack surface*).

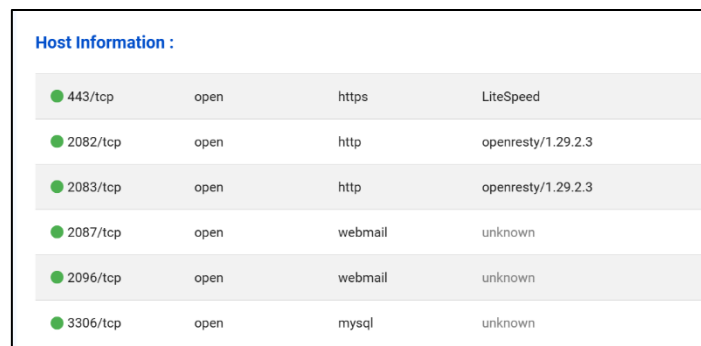
Nomor Port	Protokol	Layanan (Service)	Keterangan
21	TCP	FTP	Pure-FTPd
53	TCP	DNS	-
80, 443	TCP	HTTP, HTTPS	Web server LiteSpeed
2082, 2083	TCP	HTTP	openresty/1.29.2.3
2087, 2096	TCP	Webmail	-
3306	TCP	MySQL	Layanan basis data

Tabel 1. Identifikasi Port yang Terbuka pada Server Target



Port Number	State	Service	Version
21/tcp	open	ftp	----- Welcome to Pure-FTPd [privsep] [TLS] -----
53/tcp	open	dns	unknown
80/tcp	open	http	LiteSpeed
443/tcp	open	https	LiteSpeed

Gambar 4.1. Hasil identifikasi port yang terbuka pada server target.



443/tcp	open	https	LiteSpeed
2082/tcp	open	http	openresty/1.29.2.3
2083/tcp	open	http	openresty/1.29.2.3
2087/tcp	open	webmail	unknown
2096/tcp	open	webmail	unknown
3306/tcp	open	mysql	unknown

Gambar 4.2. Hasil identifikasi port yang terbuka pada server target.

B. Profil Teknologi (Tech Information)

Pemindai berhasil memetakan tumpukan teknologi yang digunakan oleh situs web target. Arsitektur web menggunakan CMS standar yang dioptimalkan dengan web server LiteSpeed, seperti dirinci pada Tabel 2.

Kategori Teknologi	Nama Perangkat Lunak / Versi
Bahasa Pemrograman	PHP versi 8.4.21
CMS	WordPress

Page Builder	Elementor versi 4.0.9
Web Server	LiteSpeed, HTTP/3, dan Google QUIC

Tabel 2. Profil Tumpukan Teknologi

Tech Information :	
Name	Version
PHP	8.4.21
WordPress	n/a
HTTP/3	n/a
LiteSpeed	n/a
Google QUIC	n/a

Gambar 4.3. Profil tumpukan teknologi pada situs web target.

Tech Information :	
Name	Version
WordPress	n/a
HTTP/3	n/a
LiteSpeed	n/a
Google QUIC	n/a
Elementor	4.0.9

Gambar 4.4. Profil tumpukan teknologi pada situs web target.

C. Hasil Pemindaian Kerentanan (*Vulnerability Scan Results*)

Target dilaporkan dalam kondisi *healthy* dengan status HTTP 200 dengan durasi pemindaian selama 44 menit 49 detik (25 Mei 2026). Hasil *Basic Scan* tidak menemukan kerentanan Kritis (*Critical*) atau Tinggi (*High*). Namun, terdeteksi enam temuan kerentanan berikut:

- X-Content-Type-Options Header Missing (Skor 4.3 - Medium): Server tidak mengirimkan header nosniff, memungkinkan peramban menebak tipe MIME yang berisiko disisipi skrip berbahaya.
- Strict-Transport-Security Header Not Set (Skor 3.1 - Low): Ketidadaan HSTS menyebabkan pengguna berisiko terkena serangan *downgrade* dari HTTPS ke HTTP atau intersepsi *Man-in-the-Middle* (Luthfansa and Rosiani, 2021).

- Server Leaks Information via "X-Powered-By" (Skor 3.1 - Low): Server membocorkan informasi spesifik tentang teknologi *backend* (versi PHP) yang berharga bagi penyerang pada fase pengintaian.
- Re-examine Cache-control Directives (Skor 3.1 - Low): Miskonfigurasi kontrol *cache* dapat menyebabkan informasi sensitif tersimpan sementara di peramban publik.
- Hash Disclosure (Skor 3.1 - Low): Ditemukan pola teks menyerupai struktur nilai *hash* dalam respons server yang perlu dievaluasi.
- Content-Type Header Missing (Skor 0.0 - Informational): Beberapa respons tidak menyertakan deklarasi tipe konten.

Vulnerability	Severity ↓	Port	Status
✕ X-Content-Type-Options Header Missing	4.3 - Medium		⚠ Open
✕ Strict-Transport-Security Header Not Set	3.1 - Low		⚠ Open
✕ Re-examine Cache-control Directives	3.1 - Low		⚠ Open
✕ Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	3.1 - Low		⚠ Open
✕ Hash Disclosure	3.1 - Low		⚠ Open
✕ Content-Type Header Missing	0.0 - Informational		⚠ Open

Gambar 4.5. Daftar kerentanan keamanan yang ditemukan pada sistem target.

5. KESIMPULAN DAN SARAN

A. Kesimpulan

Secara keseluruhan, postur keamanan umum sistem berada pada tingkat dasar yang cukup baik karena tidak ditemukan kerentanan Kritis seperti *SQL Injection* atau *Remote Code Execution*. Pemindaian mengidentifikasi 6 (enam) celah keamanan pada tingkat Menengah, Rendah, dan Informasional yang mayoritas disebabkan oleh miskonfigurasi keamanan pada level web server (ketiadaan implementasi *HTTP Security Headers* dan kebocoran informasi). Selain itu, terdapat 9 port terbuka yang terekspos ke publik (termasuk port 3306 dan 21) yang memperluas permukaan serangan jika tidak dibatasi aturan firewall yang ketat.

B. Saran dan Rekomendasi Mitigasi

Untuk mencegah potensi eksploitasi di masa mendatang, disarankan kepada administrator TI untuk:

1. Penerapan HTTP Security Headers: Mengaktifkan header *Strict-Transport-Security* (HSTS) pada LiteSpeed untuk memaksa jalur HTTPS, serta menambahkan header *X-Content-Type-Options: nosniff*.
2. Pencegahan Kebocoran Informasi: Menonaktifkan atau menyembunyikan header *X-Powered-By* agar versi spesifik teknologi *backend* tidak bocor.
3. Pembatasan Akses Port dan Firewall: Layanan administratif (Port 3306 dan Port 21) idealnya ditutup dari akses internet publik dan dibatasi menggunakan jaringan lokal, VPN kampus, atau *Whitelist IP*.
4. Tinjauan Kebijakan Cache dan Pembaruan Berkala: Mengatur konfigurasi *cache* untuk parameter *no-cache* atau *no-store* pada sesi otentikasi, serta rutin memperbarui versi PHP, WordPress, dan Elementor.

DAFTAR PUSTAKA

Guntoro, G., Costaner, L., & Musfawati. (2020). Analisis Keamanan Web Server Open Journal System (OJS) Menggunakan Metode ISSAF Dan OWASP (Studi Kasus OJS Universitas Lancang Kuning). *JUPI (Jurnal Ilmiah Penelitian dan Pembelajaran Informatika)*, 5(1), 45-55.

Luthfansa, Z. M., & Rosiani, U. D. (2021). Pemanfaatan Wireshark untuk Sniffing Komunikasi Data Berprotokol HTTP pada Jaringan Internet. *JIEET (Journal Information Engineering and Educational Technology)*, 5(1).

Mulyanto, Y., Haryanti, E., & Jumirah. (2021). Analisis Keamanan Website SMAN 1 Sumbawa Menggunakan Metode Vulnerability Asesement. *JINTEKS (Jurnal Informatika Teknologi dan Sains)*, 3(3), 394-400.

Riadi, I., Yudhana, A., & Yunanri, W. (2020). Analisis Keamanan Website Open Journal System Menggunakan Metode Vulnerability Assessment. *Jurnal Teknologi Informasi dan Ilmu Komputer (JTIK)*, 7(4), 853-860.

Yudiana, Y., Elanda, A., & Buana, R. L. (2021). Analisis Kualitas Keamanan Sistem Informasi E-Office Berbasis Website Pada STMIK Rosma Dengan Menggunakan OWASP Top 10. *CESS (Journal of Computer Engineering System and Science)*, 6(2), 185.